
BY COMMUNITY • FOR COMMUNITY •
#GLOBALAZURE
TORINO



Azure Meetup
TORINO

alveo®
EXPERTISE

TD SYNNEX

#GlobalAzureTorino

Microsoft Entra: Sicurezza a Prova di Attacco - Strategie, Best Practice e Protezioni Avanzate

Andrea Mennuni
Senior Systems Engineer
Durante SpA

Alessandro Appiani
Cloud Architect
Durante SpA

Azure Meetup TORINO

alveo EXPERTISE

TD SYNNEX

Alessandro Appiani



- 30+ years experience in IT Technologies and Solutions
- Computer Science Master's Degree (magna cum laude) in 1989
- Founder of Italian Association for Artificial Intelligence in 1988
- Microsoft Certified since 1995
- Microsoft TechNet speaker & Train-the-trainer since 1996
- Microsoft Most Valuable Professional 2016-2019 (Teams/Office Servers)
- Microsoft Certified Trainer since 2000
- IT Consultant & Trainer
  - Cloud Architect @ Durante SpA

@alexappiani

https://it.linkedin.com/in/alexappiani/it

alessandro@appiani.com

DURANTE
a vargroup company

#GLOBALAZURE
BY COMMUNITY • FOR COMMUNITY •
TORINO

Andrea Mennuni



- Senior Systems Engineer @ Durante SpA
- Mi occupo di: Messaging (Exchange), Identity & Security (AD, Entra ID, Microsoft 365 Defender, Microsoft Sentinel), Management (Intune)
- Sono certificato:
  - Microsoft Certified: Azure Security Engineer Associate, Azure Solution Architect Expert, Azure Administrator Associate, Security Operations Analyst Associate, Identity and Access Administrator Associate
  - Microsoft 365 Certified: Security Administrator Associate, Messaging Administrator Associate, Administrator Expert

@setol0

https://linkedin.com/in/andrea-mennuni

amennuni@durante.it

Azure Meetup TORINO

alveo EXPERTISE

TD SYNNEX

DURANTE
a vargroup company

Agenda

- Zero Trust e Identity-First
- Protezione delle identità e degli accessi
  - Base
  - Avanzata
- Hardening e gestione privilegi
- Uno step ulteriore

#GlobalAzureTorino

Zero Trust e Identity-First

Azure Meetup TORINO

alveo EXPERTISE

TD SYNNEX

#GlobalAzureTorino

Zero trust principles create a foundation for AI-ready protection



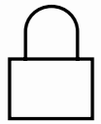
Assume compromise

Assume attackers can and will successfully attack anything (identity, network, device, app, infrastructure, etc.,) and plan accordingly



Verify explicitly

Protect assets against attacker control by explicitly validating every access request fully and equally every time

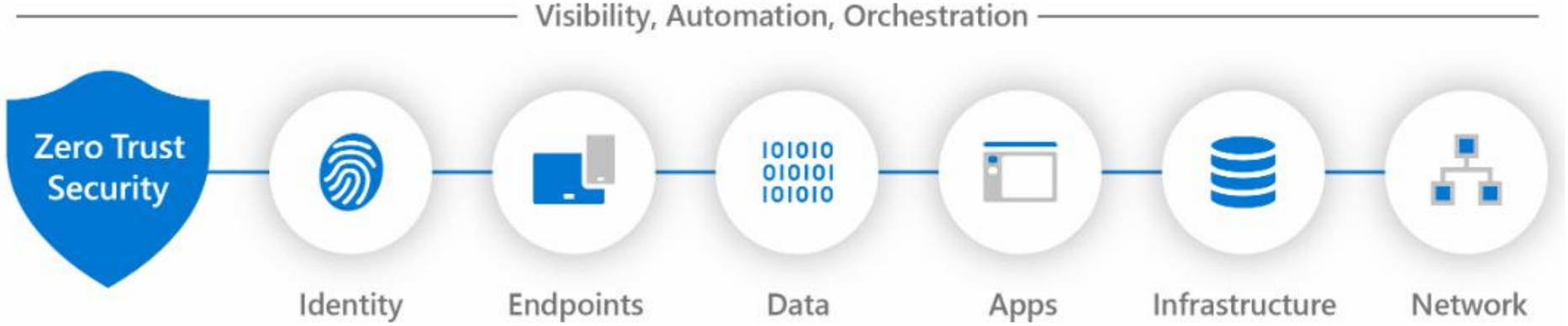


Use least privilege access

Limit access of a potentially compromised asset with policies like Just-Enough-Access

Identity & Zero Trust

- Identity is a core component
- The control plane for Cloud services



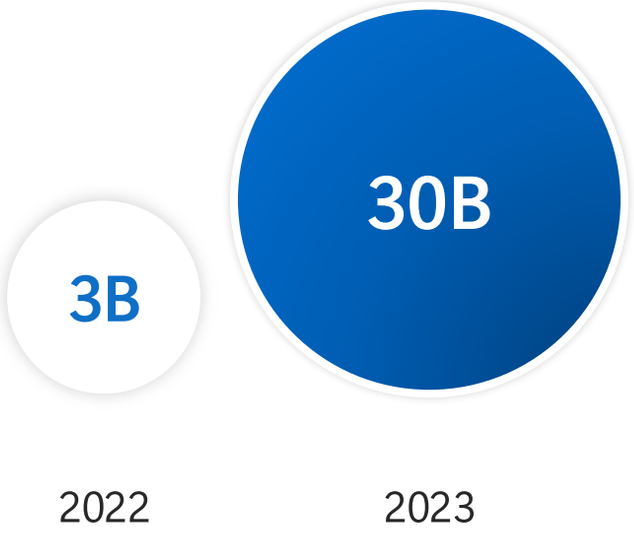
Secure identity with Zero Trust

Identities—whether they represent, people, services, devices, or event IoT devices – define the Zero Trust control plane. When an identity attempts to access a resource, verify that identity with strong authentication, and ensure access is compliant and typical for that identity. Follow least privilege access principles.

#GlobalAzureTorino

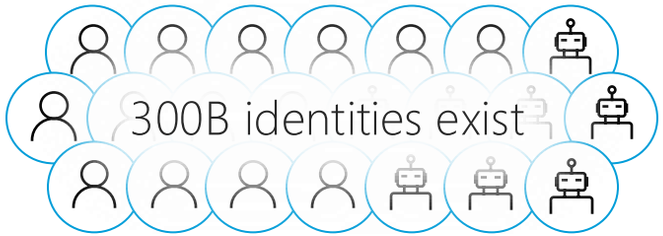
The challenge of securing access continues to intensify

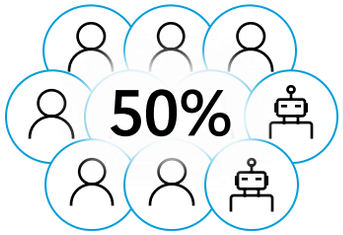
Increased attacks



Microsoft Digital Defense Report, 2023

Increased identities





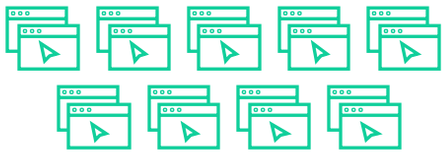
have unlimited access to all permissions and resources

Microsoft Digital Defense Report, 2023
Microsoft State of Multicloud Report, 2024

Increased apps

900

authorized apps per enterprise tenant



Service principals of top 500 tenants, Microsoft Entra 2024

#GlobalAzureTorino

Multifactor authentication (MFA) is a good start, but not enough

MFA is the first line of defense

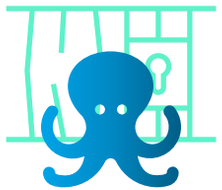
Multifactor authentication can prevent

99.9%

of identity attacks

Microsoft Digital Defense Report, 2023

Attack sophistication is growing

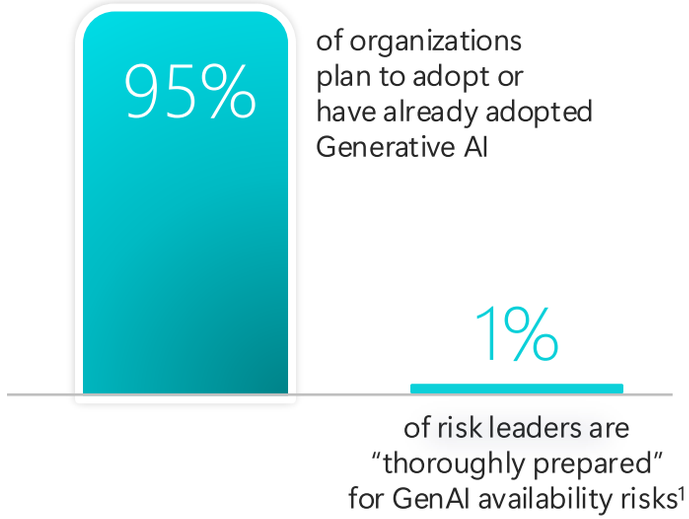


+111%

increase in token theft in just one year

Microsoft internal research, 2024

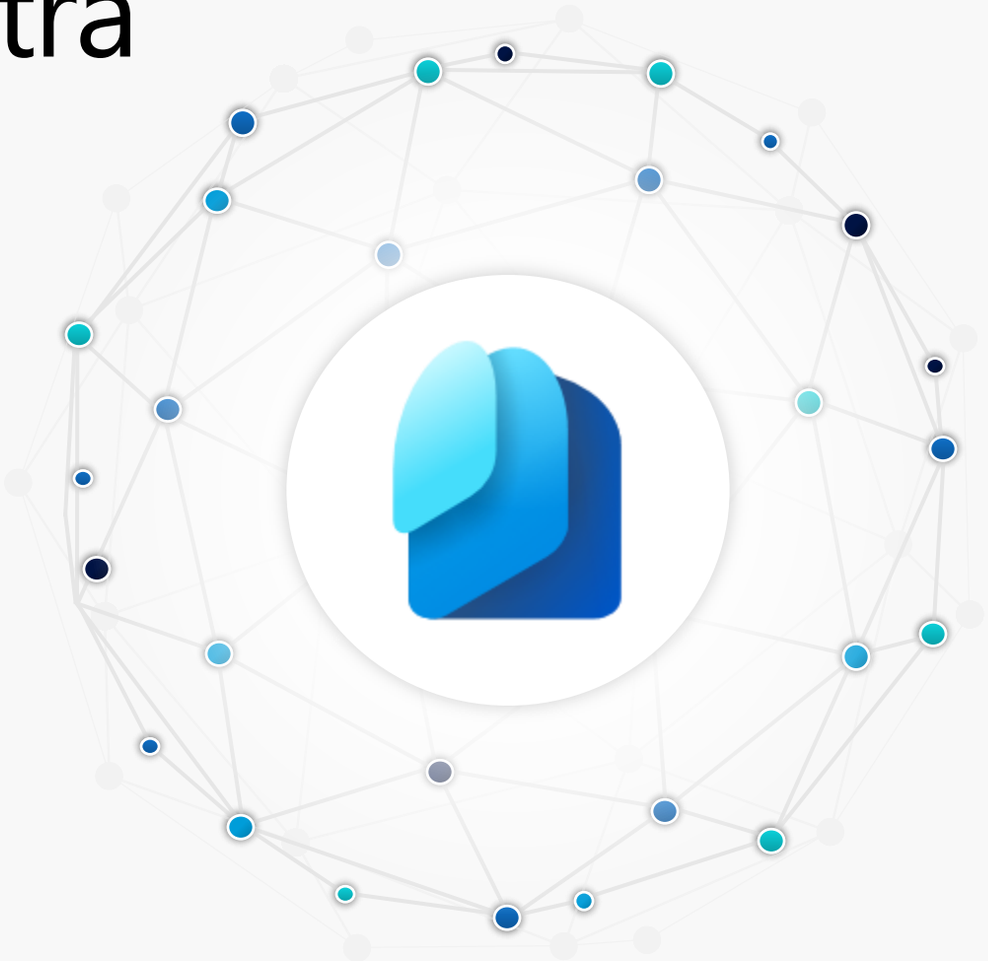
GenAI adds benefits and risks



Microsoft internal research, 2024

[1] Gartner ®, Executive Pulse: Organizations Are Not Prepared for Generative AI Risks — And They're Running Out of Time, 21st September 2023. GARTNER is a registered trademark and service mark of Gartner, Inc. and/or its affiliates in the U.S. and internationally and is used herein with permission. All rights reserved.

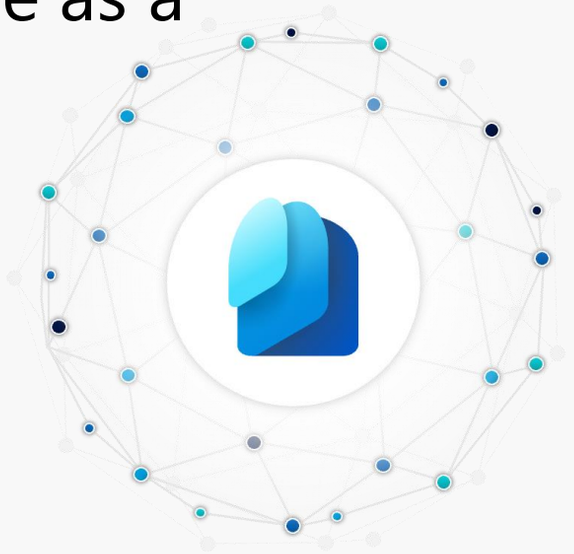
Microsoft Entra



Secure access for any identity,
from anywhere, to any app, AI, or resource

Entra for everyone

- Microsoft Entra ID **Free** - Included with Microsoft cloud subscriptions such as Microsoft Azure, Microsoft 365, and others
- Microsoft Entra ID **P1** - Microsoft Entra ID P1 is available as a standalone product or included with Microsoft 365 E3, Microsoft 365 Business Premium
- Microsoft Entra ID **P2** - Microsoft Entra ID P2 is available as a standalone product or included with Microsoft 365 E5
- Microsoft Entra **Suite** - Addon for Entra ID P1 or P2
  - Microsoft Entra Private Access
  - Microsoft Entra Internet Access
  - Microsoft Entra ID Governance
  - Microsoft Entra ID Protection
  - Microsoft Entra Verified ID (premium capabilities)



#GlobalAzureTorino

Protezione delle identità e degli accessi - Base

Entra Free

Azure Meetup TORINO

alveo EXPERTISE

TD SYNNEX

Per partire…

- Entra ID è presente in ogni Microsoft 365 Tenant e ne governa identità e accesso
- E' **fondamentale** configurarne le sicurezza
- Identity Secure Score
  - Indicazioni sulla postura di sicurezza sulle identità

Security Defaults

- Impostazioni di sicurezza pre-definite per i tenant che non dispongono delle funzionalità più avanzate delle licenze Entra ID P1/P2*
- Controlli attivi**
  - registrazione MFA per tutti gli utenti
  - MFA obbligatoria per gli admin
  - MFA richiesta agli utenti quando necessario (Microsoft managed)
  - blocco dei protocolli di autenticazione legacy
  - protezione delle attività con privilegi

* Introducing security defaults
https://techcommunity.microsoft.com/blog/microsoft-entra-blog/introducing-security-defaults/1061414
** Security defaults in Microsoft Entra ID
https://learn.microsoft.com/en-us/entra/fundamentals/security-defaults



Demo

- Identity Secure Score
- Security Defaults

Azure Meetup TORINO

alveo EXPERTISE

TD SYNNEX

Raccomandazioni (1)

- **Abilitare Security Defaults!**
- Abilitare Self-service password reset (solo per account cloud-only)
- Configurare Password Protection (solo per account cloud-only)
- **Disabilitare o gestire user consent sulle applicazioni**
- Automatizzare il provisioning degli utenti delle applicazioni SaaS
- **Utilizzare ruoli con privilegi minimi**
- Personalizzare la pagina di sign-in (Entra Branding)

Raccomandazioni (2)

- Se le identità sono sincronizzate da on-prem (Hybrid Identity)
  - Sincronizzare tutti gli utenti
  - **Abilitare Password Hash Sync**
  - Abilitare ADFS smart lockout (se si utilizza la federazione con ADFS)
  - **Implementare linee guida di Microsoft** per le password (no scadenza password periodica)
- **Abilitare Single Sign-On** (SSO) per tutte le applicazioni SaaS integrate / integrabili in Entra
- Automatizzare il provisioning degli utenti delle applicazioni SaaS

#GlobalAzureTorino

Protezione delle identità e degli accessi - Avanzata

Entra ID P1

Azure Meetup TORINO

alveo EXPERTISE

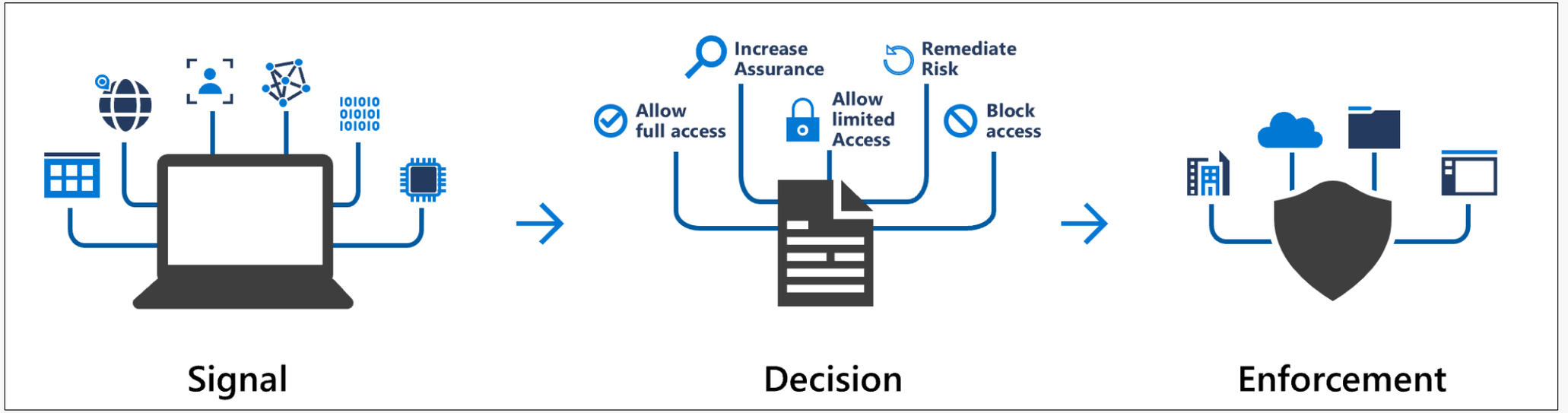
TD SYNNEX

La potenza è nulla senza controllo ☺

- Con Entra ID P1 si apre il mondo delle configurazioni, personalizzazioni, e fine tuning della sicurezza delle identità e degli accessi
  - Conditional access: il motore dello Zero Trust
  - Authentication Method, Strength, e Context: autenticazione avanzata
  - Protected actions: aumentare la sicurezza in base alle azioni
  - Role-assignable group e Administrative Units: semplificare RBAC e management delegation
- Piena integrazione delle identità On-prem e Cloud (Hybrid Identity)
  - Self-Service Password Reset anche per le password on-prem
  - Entra Password Protection delle password on-prem
  - Entra Application proxy: pubblicazione Web Application senza aperture firewall
    - con Single Sign-On verso tutte le on-prem Web Application che usano Windows Integrated Authentication (Kerberos/NTLM)

Conditional access

- Il motore dello Zero Trust
- Il «bastione» di identità e accesso
- Estremamente personalizzabile
- Sostituisce ed è alternativo ai Security Defaults



Authentication Method, Strength e Context

- Authentication Method
  - i «mattoncini» base per l'autenticazione
  - personalizzabili ed estensibili
- Authentication Strength
  - metodi di autenticazione avanzata
  - fine-tuning degli accessi con le Conditional Access Policy
- Authentication Context
  - criteri di autenticazione differenziati per accedere alla stessa app

Built-in MFA Strength

Authentication method combination	MFA strength	Passwordless MFA strength	Phishing-resistant MFA strength
FIDO2 security key	✅	✅	✅
Windows Hello for Business	✅	✅	✅
Certificate-based authentication (Multi-Factor)	✅	✅	✅
Microsoft Authenticator (Phone Sign-in)	✅	✅	
Temporary Access Pass (One-time use AND Multi-use)	✅		
Password + something you have[1]	✅		
Federated single-factor + something you have[1]	✅		
Federated Multi-Factor	✅		
Certificate-based authentication (single-factor)			
SMS sign-in			
Password			
Federated single-factor			

Protected actions

- Consentono di aumentare la sicurezza in base alle azioni eseguite
- Da attivare per l'esecuzione di azioni critiche per la sicurezza
- Vanno integrate con l'autenticazione avanzata
- Esempio: per modificare le Conditional Access Policies è richiesto l'accesso con un metodo Phishing-resistant

Administrative Units e Role-assignable group

- Zero Trust e Least Privilege Administration richiede estrema attenzione nell'assegnare ruoli con poteri globali
  - un «must» per quasi tutte le organizzazioni
- Entra ID è una directory «piatta»
  - niente gerarchia X.500 come in Active Directory (OU)
- Niente ambiti nativi per delegare l'amministrazione e limitare i ruoli
  - niente gerarchia o forest di domini (realm)
- RBAC, Admin Scope, e management delegation in Entra ID

  → Entra ID Administrative Units

  → Role-assignable group



Demo

- Role-assignable group e deleghe di management
- Conditional Access Policy
- Authentication Strengths
- Accesso con metodi phishing-resistant

Azure Meetup TORINO

alveo EXPERTISE

TD SYNNEX

Raccomandazioni (3)

- **Creare e configurare Conditional Access Policy !**
  - In presenza di Conditional Access «Block» escludere un Emergency Access Account
- **Configurare MFA per tutti gli utenti** (con authentication strength personalizzati)
- Abilitare metodi di autenticazione passwordless per gli utenti
- Controllare tramite Conditional Access e External Identity l'accesso guest
  - Tenant Access Settings
- Abilitare Protected Actions

Raccomandazioni (4)

- **Configurare piene funzionalità Hybrid Identity**
  - Abilitare Password Writeback e Self-service password reset per utenti Active Directory (sincronizzati)
  - Implementare Password Protection per aumentare la qualità delle password di Active Directory on-prem
  - Implementare linee guida di Microsoft per le password (no scadenza password periodica)
- **Abilitare l'accesso da Internet con MFA+SSO** verso applicazioni web on-prem (Application Proxy)
- Implementare Role-assignable group RBAC e Administrative Units per approccio Least Privilege Administration
  - ridurre gli amministratori con poteri «Global» (Global Admin, Intune Admin, Security Admin, ...)
  - delegare ruoli su differenti profili e ambiti (HelpDesk, Branch Admins, ...)

#GlobalAzureTorino

Hardening e gestione privilegi

Entra ID P2

Azure Meetup TORINO

alveo EXPERTISE

TD SYNNEX

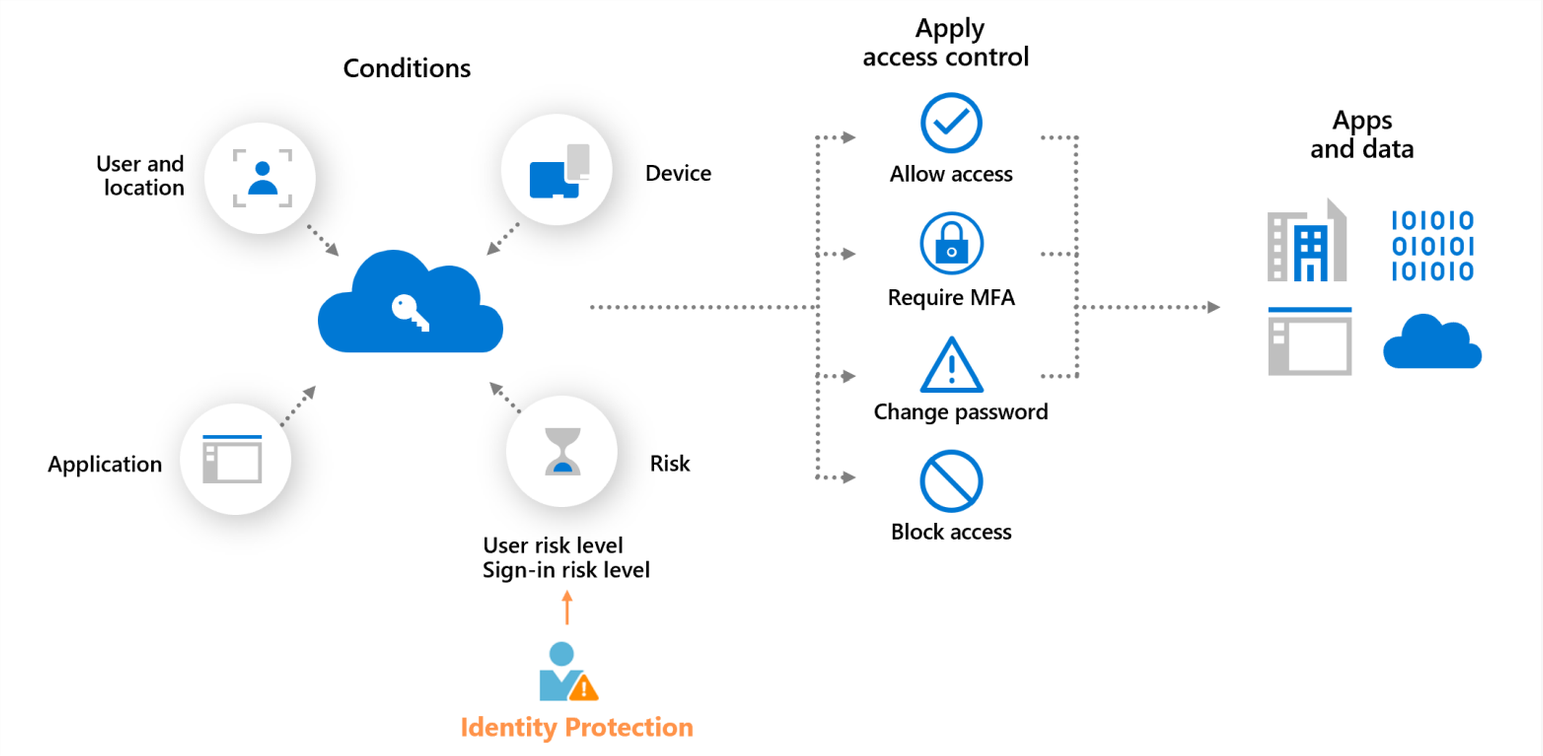
Identity Management e Governance

- Risk-based Identity Protection
  - protezione in base al rischio (Sign-in o User)
- Privileged Identity Management (PIM)
  - ruoli amministrativi solo quando servono
  - applicabile anche ai Role-assignable group
  - Just-in-time Administration
- Basic Identity Governance*
  - Access Review
  - Entitlement Management

* Microsoft Entra ID Governance licensing fundamentals
https://learn.microsoft.com/en-us/entra/id-governance/licensing-fundamentals

Risk-based Identity Protection

- Identity protection valuta dinamicamente il rischio su
  - Sign-in risk
  - User risk
- con un punteggio
  - High
  - Medium
  - Low
  - No risk
- Access control con CA Policy



Privileged Identity Management (PIM)

- Attivazione di un ruolo amministrativo in modo temporaneo tramite assegnazione (Eligible vs Permanent)
  - diretta
  - via Role-group
- Assegnazione su richiesta (Just-in-time) e con scadenza (Time-based)
- L'assegnazione (elevazione) può richiedere ulteriori vincoli
  - Autenticazione avanzata
  - Approvazione esplicita
- Applicabile a ruoli Entra, a Role-assignable group, e a risorse Azure



Demo

- Identity Protection: protezione in base al rischio
- Privileged Identity Management (PIM)

Azure Meetup TORINO

alveo EXPERTISE

TD SYNNEX

Raccomandazioni (5)

- **Configurare Conditional Access Policy basate su user e sign-in risk**
  - abilitano self-remediation
- **Abilitare e configurare Privileged Identity Management** (PIM)
  - per i ruoli built-in e per i Role-assignable group
- Configurare access review per PIM

#GlobalAzureTorino

Uno step ulteriore

Entra Suite

Azure Meetup TORINO

alveo EXPERTISE

TD SYNNEX

Microsoft Entra Suite

	Microsoft Entra ID P1	Microsoft Entra ID P2	Microsoft Entra Suite
Microsoft Entra ID	✓	✓	
Microsoft Entra ID Protection	✓	✓	✓
Microsoft Entra ID Governance	✓	✓	✓
Microsoft Entra Verified ID	✓	✓	✓
Microsoft Entra Internet Access	✓	✓	✓
Microsoft Entra Private Access			✓

✓ Partially included ✓ Included

Scenari consigliati

- Più tenant / ambienti ibridi / maggior protezione
- Gestione completa di ruoli, lifecycle, e governance
- Controllo a livello network degli accessi LAN e Internet (Global Secure Access e ZTNA)
- Gestione dinamica delle identità digitali (DID)

Microsoft Entra Internet Access for Microsoft services

- Un subset delle funzionalità di Microsoft Entra Global Secure Access sono ora incluse in Entra ID P1/P2*

Feature	**Entra P1/P2 License - Microsoft traffic profile**	Internet Access License* - Internet Access profile	Private Access License* - Private Access profile
Windows client	✓	✓	✓
macOS client	✓	✓	✓
Mobile client (iOS, Android)	✓	✓	✓
Traffic logs	✓	✓	✓
Remote network (branch connectivity)	✓	✓	
Universal Tenant Restrictions	✓		
Compliant network check	✓		
Source IP restoration	✓		
Microsoft 365 Enriched logs	✓		
Universal Conditional Access (CA)	✓	✓	
Context-aware network security		✓	
Web category filtering		✓	
Fully qualified domain name (FQDN) filtering		✓	
Universal Continuous Access Evaluation (CAE)	✓	✓	✓
VPN replacement with an identity-centric ZTNA			✓
Quick Access			✓
App Discovery			✓
Private Domain Name System (DNS)			✓
Single sign-on across all private apps			✓
Marketplace availability			✓
Private network connector multicloud support			✓

* https://learn.microsoft.com/en-us/entra/global-secure-access/overview-what-is-global-secure-access#licensing-overview



Demo

- Tenant restrictions
- Compliant Network controls
- Universal Conditional Access

Azure Meetup TORINO

alveo EXPERTISE

TD SYNNEX

Call to Action

Alza la sicurezza delle tue identità

→ si può fare con tutte le versioni di Entra, anche la Free!

Dota il tuo tenant di Entra ID P1 o superiore

→ è inclusa nella M365 Business Premium e nella M365 F3/E3/E5

→ abilita un sacco di protezioni e personalizzazioni

Follow us @:

https://globalazuretorino.welol.it/

https://www.meetup.com/it-IT/meetup-microsoft-azure-torino/


BY COMMUNITY • FOR COMMUNITY •
#GLOBALAZURE
TORINO